1.Soru – ABMCTF – Ghost Stream

“Flag Erişim” – Yasadışı Yayın Analizi Senaryosu

Bir siber araştırma ekibinin parçası olarak, yıllardır yasadışı spor yayınları sağlayan bir organizasyonun altyapısını incelemekle görevlendirildin. Söz konusu platform, yüzeyde sıradan bir canlı yayın sitesi gibi görünse de arka planda oldukça karmaşık bir CDN yapısı, özelleştirilmiş bir cache katmanı ve çeşitli yönlendirme mekanizmaları barındırmaktadır.

Siteye giriş yaptığında seni tamamen işlevsiz fakat gerçekçi şekilde tasarlanmış “fikstür”, “puan durumu”, “özetler” gibi arayüz bileşenleri karşılıyor. Bunlar operasyonel olarak hiçbir işe yaramasa da platformun gerçekmiş gibi görünmesini sağlıyor. Login ve Register fonksiyonları çalışmıyor; bunun bilinçli bir sis perdesi olduğu anlaşılıyor.

Yayın akışının Steam üzerinden yapıldığı belirtilmiş ve sistem, broadcast kaynaklarını dinamik olarak seçebilen bir parametre yapısı kullanıyor. Kullanıcıya sunulan örnek akış şöyle:

http://localhost/abmctf/stream.php?source=cdn-backup-02&ch=1&stream=live

source → Yayın alınan CDN kaynağı
stream → “live” olarak işaretlenmiş aktif akış
ch → yayının kanal numarası

Sayfada dolaşırken “Özetler” sekmesine tıkladığında sahte bir SQL hata mesajı ile karşılaşıyorsun:

#2 /var/www/html/stream.php(204): CacheLayer->resolve(source='internal-cdn', file='ARGvsSAU_highlights.mp4')

Bu hata bir dikkat dağıtıcı değil; aynı zamanda kritik bir ipucu. Hata, backend fonksiyonunun file parametresi üzerinden medya dosyalarını çözdüğünü açıkça gösteriyor. Bu, potansiyel olarak dosya dahil etme (LFI) türü bir zafiyete işaret ediyor.

Doğrudan:

http://localhost/abmctf/stream.php?source=a&file=flag.txt

ile flag dosyasına erişmeye çalışırsan sistem hata döndürüyor.
Bu, erişim kontrolünün yalnızca belirli kaynak IP’lere izin verdiğini düşündürüyor.

Derin inceleme için “Sistem Durumu” ekranında yer alan bant genişliği, izleyici sayısı ve cache istatistikleri gibi bilgiler incelendiğinde response içeriğinde kritik bir veri fark ediliyor:

"origin_source_ip": "204.236.245.151"

Bu, yayınların gerçekten alındığı orijin sunucunun gerçek IP adresi.
Cache ve CDN katmanlarının arkasına saklanan çekirdek sunucu.

Bu IP’yi source parametresi olarak kullanırsan cache katmanı bypass ediliyor ve backend doğrudan dosya isteğini işliyor. Bir nevi SSRF + LFI tipinde bir zafiyet fakat farklıda yorumlanabilir. :

http://localhost/abmctf/stream.php?**source=204.236.245.151&file=flag.txt**

Böylece flag başarılı şekilde elde edilir.

CTF Senaryo Açıklaması

Bu görevde, yasadışı canlı yayın sağlayan bir grubun dağıtık yapıdaki içerik ağını incelemekle görevlendirilen bir araştırma ekibinin üyesisin. Amacın yalnızca domain adresini engellemek değil, yayın trafiğini asıl yöneten gizli sunucusunu tespit ederek operasyonu kökten durdurmak.

Görevin; cache katmanının arkasındaki gerçek sunucuya ulaşmak, yayın motorunun dosya çözümleme mekanizmasını manipüle etmek ve nihayetinde sistemde saklanan **flag.txt** dosyasına erişmek.

Soru 2 – "Chemical Horizon: Compromised Control Room"

Modern bir kimyasal depolama tesisinde kullanılan **EKS / SCADA tabanlı kontrol paneli**, gece saatlerinde beklenmedik şekilde anormal davranışlar göstermeye başladı. Operasyon merkezi, tank basıncı, kimyasal ısı değerleri ve dolum seviyelerinde **dakikalar içinde yükselen düzensizlikler** fark etti. Kısa süre sonra sistem üzerindeki pek çok kritik ayarın dışarıdan manipüle edildiği ortaya çıktı. Bu olayların hemen öncesinde, sistem mühendislerimizden biri gariplik fark etmiş ve yönetimi uyarmıştı; ancak kendisine ulaşmaya çalıştığımızda yanıt vermediğini gördük. Personelin **ev güvenlik kamerası sistemine dair bir erişim paneli** bulunduğuna dair ihbar alındı. SCADA sistemine tek erişimi sağlayabilecek kritik bilgilerin bu ev kameralarından ulaşılabileceği bir şekilde yer aldığı düşünülüyor. Zamanımız çok kısıtlı: Kimyasal tank kritik seviyeye hızla yaklaşıyor ve kontrol odası çevrimiçi değil. Bu kaotik ortamda, **Siber Güvenlik Uzmanı** olarak sizden yardım istendi. SCADA paneline yeniden erişim sağlanması, sabotajı yapan kişilerin bıraktığı izlerin takip edilmesi ve tankın güvenli şekilde stabilize edilmesi gerekiyor. Ayrıca çalışanımıza ait çeşitli "**signature"** dosyaları ve şifreleme anahtarları ele geçirildi; ancak bunların nasıl kullanılacağı belirsiz. Tüm bu bilgi kırıntılarını kullanarak doğru erişim zincirini oluşturmak tamamen size kalmış durumda.

Çözüm Yoluna Genel Bakış

1) **İlk Temas – MAC Adresi ile Marka Tespiti**

http://localhost/abmctf2/ adresindeki panel açıldığında çalışanımıza ait kameranın **MAC adresi** görüntüleniyor:

38:AF:29:11:22:33

Bu adres **Zhejiang Dahua Technology Co., Ltd.** üreticisine ait olduğu görülebiliyor. Böylece sistemde hangi OEM kameranın kullanıldığı ortaya çıkıyor ve ilgili **varsayılan kimlik bilgileri** araştırılabiliyor. Default bilgilerden ***user: 666666*** / ***pass: 666666*** ile giriş sağlayabiliyoruz.

---

2) Ev İçi Kamera Sisteminde Bilgi Avı
Giriş sonrası dashboard:

http://localhost/abmctf2/dashboard.php

Farklı kamera açılarına ait görüntülerde:

- Dağınık masa üzerindeki **defter ve etiketler**,
- Duvara sabitlenmiş **mini SCADA çizimleri**,
- Karışık teknik notlar,
- Kimyasal tanklara ait **referans blokları**,
- Ve ciddi şekilde bulanık ama çözülmesi mümkün "ipucu" objeleri yer alıyor.

Her kamera bir bilgi veriyor:

- **CAM-1 → Parola:** ics528c8bn91a
- **CAM-2 → Panel Kısmı / Dizini:** 11c77c2c-2bb2-4561
- **CAM-3 → Kullanıcı:** bilgehan.425d-52bb62-4551@icscontrolsystems.local

Bu üç bilgi bir araya getirildiğinde:
http://localhost/abmctf2/11c77c2c-2bb2-4561/
adresinden SCADA yönetim paneline giriş yapılabiliyor.

---

2) İkinci Katman – Signature Hash Doğrulaması (2FA)

Sistem, sabotaj sonrası güvenlik moduna girdiği için ikinci bir doğrulama istiyor. Panelde yüzlerce küçük "signature görseli" bulunuyor.
Katılımcıya verilen hash:

bc7e2596737fccf9f22697a55112b321

Tüm görsellerin MD5 hash'leri karşılaştırıldığında:
📌 **Sig-271**

hash eşleşmesi sağlayan imza dosyası oluyor.
Böylece sistemde oturum başarıyla açılıyor.

---

3) Kritik Görev – 9 Alarmın Stabilize Edilmesi

Karşımıza çıkan panel, sabotajın etkilerini net şekilde ortaya koyuyor:

- 9 adet sensör alarm veriyor,
- Basınç limitleri şişmiş,
- Sıcaklık değerleri kritik eşiğe dayanmış,
-
- Tankın dolum kontrolü anlık hatalar üretiyor.

Her sensörün **referans değerleri** şu adresteki tablodan görülebiliyor:

http://localhost/abmctf2/11c77c2c-2bb2-4561/reference.php

Ayrıca API'nin nasıl kullanılacağı da açık bir şekilde belirtiliyor:

http://localhost/abmctf2/11c77c2c-2bb2-4561/docs.php

Görev:

Her sensörü API üzerinden doğru parametrelerle güncellemek ve sistemi **normal referans değerlerine geri döndürmek**.
Yanlış ayarlar, kimyasal tankın:

- Aşırı ısınıp **termal runaway** yaşamasına,
- Basınç valflerinin geç devreye girmesine,
- Soğutucuların tetiklenmemesine,
- Hatta **patlama riskine** yol açabilir.

Bu nedenle işlem zaman kritiktir.

Sonuç

Bu CTF senaryosu hem OSINT, hem IoT kamera zafiyetleri, hem hash signature doğrulama, hem de ICS/SCADA API manipülasyonu gerektiren çok katmanlı bir yapıya sahiptir.

Amacınız:
✓ Kamera sisteminden doğru bilgileri toplamak
✓ SCADA paneline sızmak
✓ Sabotaj sonrası hatalı sensör değerlerini API ile düzeltmek
✓ Kimyasal tankı güvenli seviyeye geri döndürmek
Başarıyla tamamlandığında operasyon kurtarılmış olur ve Flag direkt olarak panelde görünmektedir.

Soru 3 – "InboxRansom: Quarantined Payload Alert"

Havacılık teknolojileri üzerine çalışan **FlightCore** firmasının kurumsal iç iletişim platformu **MailSuite v2.4 Enterprise**, son 48 saat içerisinde olağandışı ve açıklanamayan aktiviteler üretmeye başladı. Siber istihbarat birimlerimiz, sistem yöneticisi tarafından tüm personele gönderilen **"Critical Patch Deployment"** konulu bir e-postanın, gönderildikten **yalnızca 1 saniye sonra** "*[QUARANTINED]*" işlemine alınarak erişimden silindiğini tespit etti.

Normalde MailSuite, geri çağrılan maillerin hem içeriklerini hem meta verilerini arayüzden tamamen kaldırır.

Fakat… Bu sürümde tespit edilen mimari bir hata, "geri çağrılmış" maillere ait:

- uuid (benzersiz kimlik),
- telemetri id,
- zaman damgası,
- alt süreç log referansları

gibi kritik bilgilerin hâlâ **HTTP Response** çıktılarında sızmasına sebep oluyor.

Bu açık, saldırganlara yalnızca geri çağrılan mailin kimliğini değil; aynı zamanda **kurumsal telemetri servisine ait gizli bir yönetici token'ını** da elde etme imkânı veriyor.

Görev Tanımın
Sızdırılan çalışan hesabına giriş yapacak, sistemin ön uç ve arka uç davranışlarını inceleyecek ve geri çağrılmış yönetsel e-postanın içindeki **FLAG** değerini elde edeceksin.
Yetkilendirilmiş Hesap:

- **E-posta:** bilge.demir@flightcore.com
- **Parola:** @bilge15123.1u65ET€₺#$.!

---

eknik Yapı – Sistem Nasıl Çalışıyor?

1. **MailGeneratorService – Dinamik Mail Motoru**

Kullanıcı her istek yaptığında sistem:

- O anki sunucu saatini referans alır,
- 30’ar saniye geriye giderek **15–20 adet sanal mail** üretir,
- Her mail için **UUID v4** oluşturur,
- Döngü içerisine statik bir özel mail yerleştirir:
-

UUID: f3c12a6d-8f91-4b9c-96c3-4e98ddc8ba1f
Gönderen: admin@flightcore.com
Durum: is_recalled = true
Konu: [RECALLED]

Bu mail **GUI’de görünür**, ancak “erişilemez” olarak işaretlenmiştir.

---

2. Front-End Tarafında Bırakılan Kritik Kurumsal Hatalar
public/assets/js/mail.js içinde iki büyük güvenlik hatası bulunur:

⚠️ **(1) Gizli Telemetri Token’ı Unutulmuş**
_INTERNAL_TELEMETRY_TOKEN = "FLIGHTCORE_SYS_ADM_99127x!";
⚠️ **(2) Gizli Telemetri API Endpoint’i Unutulmuş**
/api/v1/internal/telemetry

Bu ikisi birleştiğinde saldırgan, geri çağrılmış maile ait log ve içerik parçacıklarına doğrudan erişebilir.

Writeup / Çözüm Akışı (Oyuncunun İzlemesi Gereken Yol)
Sistem Girişi ve Arayüz İncelemesi
Oyuncu verilen kullanıcı bilgileriyle sisteme giriş yapar.
Gelen kutusunda soluk/italik görünen ve üzerinde:
[QUARANTINED] URGENT: Ransomware Attack Attempt Detected
ibaresi olan bir mail vardır.
Tıklanmak istendiğinde:
HATA: Bu e-posta idari bir kararla veya güvenlik kalkanı (WAF) tarafından engellenerek geri çekilmiştir.
uyarısı gelir.

HTTP Response Analizi ve Kaynak Kodu İncelemesi
Oyuncu F12 geliştirici konsolunu açar:
🔍 **Network → inbox.json cevabı**
Response içerisinde geri çekilen mailin UUID’si hâlâ görünür:
f3c12a6d-8f91-4b9c-96c3-4e98ddc8ba1f
🔍 **Sources → mail.js**
Burada şu değerler keşfedilir:

- Token: **FLIGHTCORE_SYS_ADM_99127x!**
- Endpoint: **/api/v1/internal/telemetry**

Bu iki bilgi tek başına exploitation için yeterlidir.

3️⃣ **İstismar – Telemetri API’sine Manuel POST Atma**
Kullanıcı şimdi geri çağrılmış maile ait logları çekmek için POST isteği oluşturur.
Örnek cURL Komutu

```
curl -X POST http://<IP>/api/v1/internal/telemetry \
  -H "X-Internal-Token: FLIGHTCORE_SYS_ADM_99127x!" \
  -H "Content-Type: application/json" \
  -d '{"uuid":"f3c12a6d-8f91-4b9c-96c3-4e98ddc8ba1f"}'
```

Sunucu Doğrulama Yanıtı
Başarılı istek sonucunda sistem, geri çağrılmış mailin:

- içeriğini,
- metadata parçacıklarını,
- admin tarafından gömülü olarak gönderilen **Deployment Key / FLAG** bilgisini

geri döndürür.

Sonuç

Oyuncu tüm bu adımları tamamladığında, FlightCore sisteminden geri çağrılan yönetsel mail içindeki **FLAG** değerini başarılı şekilde elde eder ve görevi tamamlar.

λ curl -X POST "http://localhost/ABMCTF3/api/v1/internal/telemetry.php" -H "Content-Type: application/json" -d "{\"mail_id\":\"f3c12a6d-8f91-4b9
c-96c3-
4e98ddc8ba1f\",\"auth_token\":\"FLIGHTCORE_SYS_ADM_99127x!\"}"

{"status":"success","telemetry_log":{"event":"WAF_QUARANTINE_CRITICAL","mail_id":"f3c12a6d-8f91-4b9c-96c3-4e98ddc8ba1f","original_payload_dump":
{"subject":"URGENT: Ransomware Attack Attempt Detected","attacker_message":"Your incompetent IT team tried to hide this from you, but your netwo
rk is ours. We gained full domain admin privileges because they failed to patch basic vulnerabilities. We know exactly which machine we breached
 first and who is responsible.","technical_details":{"responsible_person":"Okan Yilmaz (Senior Network Admin)","compromised_email":"okan.yilmaz@
flightcore.com","compromised_host":"FC-IST-IT-WS-04","domain_controller":"DC01-MAIN.flightcore.local","vulnerability_used":"Opened malicious att
achment & Unpatched Endpoint (CVE-2024-XXXX)","lateral_movement":"RDP access to DC01-MAIN using cached admin credentials found on Desktop"},"ran
som_key_hex":"41424d4354467b666c316768745f633072335f6d34316c5f7634756c745f6279703473735f323032367d"}}}

Senaryo Metni :

FlightCore kurumsal ağı son günlerde garip davranışlar göstermektedir.
Kullanıcılar zaman zaman yavaşlama, oturum düşmesi ve bazı uygulamaların cevap vermemesi gibi şikayetler ile IT ekibine başvurmaktadır.
Buna rağmen IT ekibi “her şey normal” diyerek durumu geçiştirmiş, herhangi bir olay bildirimi yapılmamıştır.
Ancak bugün, şirketin karantina sistemi beklenmedik bir şekilde alışılmadık bir e-posta tespit ederek yönetime otomatik alarm düşmüştür.
Uyarı mesajının içeriği IT ekibinin bilerek gizlediği kritik bir gerçeği ortaya çıkarmaktadır.
Bu durum, saldırganların hâlâ içeride olabileceğini ve IT ekibinin gerçekte ne olduğunu söylemediğini düşündürmektedir.
Şirket yönetimi olayı gizlice yönetmen ve araştırman için tamamen sana devretti.